Phase 1,2,3
Project Selection, Description & Analysis

Secure Software Development (CYS402 - Section 1407)

Instructor: Dr. Zainab Masood

Done by:

Sarah Alakal	221410617
Meshael Alotabi	221511285
Rinas Naif	221411054
Aljohara Alnasser	223410291

Overview of the Software Domain

Onion Browser is an open-source, security- and privacy-oriented web browser that enables anonymous internet communication through integration with the Tor (The Onion Router) network. The browser enforces traffic routing through layered encryption across multiple Tor relay nodes, which prevents direct linkage between the user and the destination server. By design, Onion Browser mitigates threats such as traffic correlation, IP address disclosure, network surveillance, and content filtering, while also supporting access to Tor hidden services (.onion).

The source code for Onion Browser is publicly available and maintained on GitHub at the following link:
https://github.com/OnionBrowser/OnionBrowser

Onion Browser operates within the secure communications and privacy-preserving software domain, which is a critical subset of cybersecurity systems. Software in this domain is designed to protect users against both passive and active adversaries, including internet service providers, malicious network observers, and state-level surveillance entities. Security is a fundamental requirement because the browser handles highly sensitive data such as encrypted network traffic, session metadata, and user browsing behavior. Any weaknesses in cryptographic implementation, traffic isolation, or browser sandboxing could lead to deanonymization attacks, data leakage, or user compromise. As a result, strong security architecture, defense-in-depth mechanisms, and continuous security assessment are essential to ensure the browser's reliability and trustworthiness in high-risk environments.

Identification of Significant Security Risks

1. **Data Breaches**

Risk: personal information may be exposed.
Cause: browser vulnerabilities , unsafe website, external attacks.

2. **Unauthorized access**

Risk: Unauthorized users can access resources without permission.
Cause: weak password, entering an unsafe network, malware targeting users.

3. **User Tracking**

Risk: User activity being tracked.
Cause: visiting malicious websites, info leaks, wrong configuration.

4. **System Outages**

Risk: browser becomes slow or stops.
Cause: High traffic, Dos, attack on the network.

5. **External Attacks**

Risk: Browsers may be attacked by phishing.
Cause: visiting unsafe websites, clicking on suspicious links, hacker attack.

Data Protection

The Onion Browser was created to ensure users are able to protect their Privacy and Anonymity while browsing the web. Utilization of sensitive data such as IP Addresses, Browsing Activity, and Network Traffic Metadata is managed by Onion Browser using the Tor Network, as well as attempting to limit Local Storage to minimize Privacy and security risk.

Onion Browser employs various measures to protect user data, including the following:

- Multiple Layers of Encryption for Internet Traffic delivered through the Tor Network.
- Masking the user's True IP Address by routing Traffic through multiple Tor Relay Nodes.
- Automatically delete Browsing History, Cookies, and Cached Data.
- Support for: HTTPS Communication for Data Confidentiality and Integrity during transmission.

Potential Weaknesses and Areas for Improvement Include:

- Exposure of User Data when Visiting Unsafe or Malicious Websites (for example, non-HTTPS websites).
- User Enabling Insecure Browser Settings or Installing Untrusted Add-ons may have compromised Data Protection Mechanisms.
- The level of Data Protection is Uniquely Tied to the Security of the User's Device and Operating System, which may introduce Vulnerabilities beyond the Browser's Control.

Consequences of Security Failures

Browser security failures can lead to significant and serious consequences, especially for users who value their privacy and anonymity. Among the most prominent of these consequences are:

1- Unauthorized Access

If there are weaknesses in the system's security, this could allow an unauthorized attacker to access system resources and control user sessions. This poses a very serious threat to the security of user data.

2- Loss of System Trust

Repeated security failures erode user trust in the system's security. The user may lose confidence in the system's security.

3- Leakage of Sensitive Data

A security failure can lead to the leakage of sensitive user data, such as browsing history and personal information. This increases the risk of exploitation and blackmail.

4- Negative Impact on Setup and User Experience
Breaches and attack attempts on the system lead to resource consumption and, most importantly, slow performance and system instability. This significantly impacts the efficiency of daily use.

5- Increased Potential for Social Engineering
Weak security can allow an attacker to collect a large amount of user data and use it later in more convincing social engineering attacks.

6- Manipulation of Displayed Page Content
If the secure channel is compromised, the content displayed to the user can be modified, such as adding links to fake websites or other potentially harmful content.

The consequences of security failures in the system, which focus on privacy and protecting sensitive data for authorized users, are not limited to the financial aspect but also include human, legal, and ethical considerations. Therefore, any security weakness can have significant and potentially irreversible effects on the user or the system.

Team Contribution

The team used a peer-review approach to complete the project. Each section was assigned a team member to work on it and another team member to review it to ensure accuracy, completeness, and quality. This process helped maintain consistency across the document and meet all project requirements.

Team Member	Project Section	Reviewed Portion
Sarah Alakal	Overview of the Software Domain	Data Protection
Meshael Alotabi	Identification of Significant Security Risks	Overview of the Software Domain
Aljohara alnasser	Data Protection	Consequences of Security Failures

Rinas Naif	Consequences of Security Failures	Identification of Significant Security Risks

Table of content

Part 1: Product Assets **3**
- Listing and Discussion 3
  - Prioritization 4
  - Decision Process 4
  - Future Changes 4

Part 2: Malicious Actors & Threats **5**
- High-level Threats (STRIDE & CIA) 5

Part 3: Software Security Requirements (SQUARE-Lite) **6**
- Step 1: Agree on Definitions 6
- Step 2: Identify Security Goals 6
- Step 3: Identify Supporting Artifacts 7
- Step 4: Perform Risk Assessment 7
- Step 5: Select Elicitation Techniques 8
- Step 6: Elicit Security Requirements 8
  - Agree on Definition: 9
  - Identity Security Goals: 9
- Elicit Security Requirements: 9
- Elicit Security Requirements 10
- Step 7: Categorize Requirements 11
- Step 8: Prioritize Requirements 12
- Step 9: Inspect Requirements 13

Team Contribution **13**

Part 1: Product Assets

Listing and Discussion

Onion Browser manages several critical assets that may be targeted by malicious actors. These assets include both tangible and intangible components of the system:

-**User Anonymity**: The ability to prevent identification of the user's IP address, location, and identity while browsing.

-**Network Traffic Data**: Encrypted traffic routed through the Tor network, including requests, responses, and session metadata.

-**Browser Integrity**: The correctness and trustworthiness of the browser's codebase, configurations, and updates.

-**User Configuration and Preferences**: Security-related settings such as JavaScript behavior, cookie handling, and connection preferences.

-**Application Availability**: Continuous and reliable access to the browser and Tor network without disruption.

Prioritization

1. User Anonymity
2. Network Traffic Data
3. Browser Integrity
4. Application Availability
5. User Configuration and Preferences

Decision Process

Assets were prioritized based on their impact on user safety and privacy if compromised. User anonymity and encrypted network traffic were ranked highest because their exposure could directly lead to deanonymization and personal risk. Browser integrity was prioritized next, as compromised code could undermine all security controls. Availability and user configuration were ranked lower but remain important for usability and secure operation.

Future Changes

As Onion Browser evolves, additional assets such as plugin support, enhanced cryptographic mechanisms, or integration with new Tor features may be introduced. These changes could shift asset prioritization, especially if new features expand the attack surface or introduce additional sensitive data.

Part 2: Malicious Actors & Threats

Types of Attackers

1- Individual Hackers
Motives: Technical curiosity, challenge, achieving fame within the hacking community, or financial gain.
Skill level: Ranges from beginner using readily available tools to professional with advanced experience in vulnerability analysis and penetration testing.

2- Cybercriminal Groups
Motives: Financial gain through data theft, selling information on the black market, carrying out ransomware or phishing attacks.
Skill level: Intermediate to high; they often work within organized teams that possess modern tools and technologies.

3- State - Sponsored Actors
Motives: Espionage, surveillance, intelligence gathering, or tracking specific activities.
Skill level: Very high, as these entities possess enormous financial and technological resources and cybersecurity experts.

4- Network Observers/ISPs
Motivations: Monitoring activity and compliance with local laws, or analyzing data for regulatory purposes.
Skill Level: Network and Data Traffic Analyst

5- Social Engineering Attackers
Motives: To steal data and accounts by deceiving users.
Skill level: They may not need advanced skills, but they possess strong persuasion and deception skills.

Available Information

Types of sensitive data that may be accessed:

- Browsing history and online activity
- User's real IP address
- Network traffic descriptive data
- Device and operating system information
- Login data and passwords
- Cookies and session data

What information is most valuable?

- Login data: Can be used to compromise other accounts.
- Browsing history: May contain sensitive information or private activity.
- Real IP address: May reveal the user's identity or geographic location.
- Network metadata: Can be used in traffic analysis attacks to identify the user.

Where is the information stored?

1- On the user's device:
- Temporary browsing history
- Application-related system files
- Cookies
- Cached memory

2- In the application-related cache:
- Temporary encryption keys
- Active session data

3- Within the Tor network:
- Data is passed through multiple nodes with multiple encryption layers, but some nodes may see unencrypted data if the connection is not over HTTPS.

4- On the website servers visited:

- Access logs
- IP addresses and session data
- Login data

High-level Threats (STRIDE & CIA)

- Spoofing: An attacker pretends to be a trusted website to trick the user.
- Tampering: attacker changes the data while its benign sent or received.
- Repudition: attacker denies doing something like an action because there are no clear logs.
- Information disclosure: private info being exposed
- DoS: Attacker overload the browser so users cannot access it.
- Elevation of privilege: after exploiting a vulnerability an attacker can have higher access rights.

CIA IMPACT

- Confidentiality: Private user data may be exposed or leaked.
- Integrity: Data changing without permission.
- Availability: The browser may stop working.

Exploitation Methodes:

- Attackers may scan for vulnerabilities.
- Attackers may send malware through downloas.
- Attackers may create phishing websites.
- Attackers may exploit security weaknesses.

Threat Distribution:

- Spoofing → Confidentiality & Integrity
- Tampering → Integrity
- Repudiation → Integrity
- Info disclosure → Confidentiality
- DoS → Availability
- Elevation of privilege → Confidentiality, Integrity & Availability

Part 3: Software Security Requirements (SQUARE-Lite)

Step 1: Agree on Definitions

The project team agreed on a shared set of security definitions through discussion and review of course materials to ensure consistent interpretation of security concepts.

- **User Anonymity:** The inability to associate browsing activity with a specific user, IP address, or physical location.

- **Confidentiality:** Protection of data from unauthorized disclosure.

- **Integrity:** Assurance that software and data are not modified without authorization.

- **Availability:** The ability of the system to remain operational when required.

- **Denial of Service (DoS):** An attack intended to disrupt system availability.

Identity Security Goals:

- Protect user identity.
- Prevent unauthorized access.
- Ensure secure communication.
- Prevent data tampering during transmission.
- Maintain browser avalibity.

Exit Criteria: Documented and agreed-upon definitions.

Step 2: Identify Security Goals

Based on the system's purpose and threat environment, the following security goals were identified:

1. Preserve user anonymity at all times.

2. Protect confidentiality of network traffic.

3. Maintain integrity of browser software and updates.

4. Ensure secure operation during failures or attacks.

5. Maintain availability without compromising security.

Step 3: Identify Supporting Artifacts

The following artifacts were used to support requirement development:

-Onion Browser GitHub source code

-Tor network documentation

-Course materials on SQUARE and STRIDE

-Browser architecture and configuration settings

Step 4: Perform Risk Assessment

A high-level risk assessment identified the most significant risks as:

-Deanonymization of users

-Traffic interception and analysis

-Malicious software updates

-Configuration tampering

-Service disruption through DoS attacks

Step 5: Select Elicitation Techniques

Security requirements were elicited using:

-Threat modeling

-Risk-based analysis

-Review of known Tor and browser vulnerabilities

Step 6: Elicit Security Requirements

SR-1 (Author: Sarah Alakal)
The system shall route all browser network traffic exclusively through the Tor network to prevent IP address disclosure.

SR-2 (Author: Sarah Alakal)
The system shall apply layered encryption to all transmitted data to protect confidentiality from network observers.

SR-3 (Author: Sarah Alakal)
The system shall verify the integrity of all software updates before installation to prevent execution of malicious code.

SR-4 (Author: Sarah Alakal)
The system shall prevent unauthorized modification of security-critical configuration settings.

SR-5 (Author: Sarah Alakal)
The system shall maintain anonymity protections during network failures without leaking sensitive user information.

SR-6 (Author: Meshael Alotabi)
The system shall encrypt all users traffic using end to end encryption for protection.

SR-7(Author: Meshael Alotabi)
The system shall prevent IP address leakage.

SR-8(Author: Meshael Alotabi)
The system shall block access to browsers using insecure http.

SR-9 (Author: Meshael Alotabi)
The system shall check all downloaded files with a virus detector or malware scanner.

SR-10(Author: Meshael Alotabi)
The system shall clear browsing history automatically after each session.

SR-11 (Author: Aljohara Alnasser)
Using current threat intelligence feeds, the system must identify and stop users from accessing known phishing/supported phishing websites.

SR-12 (Author: Aljohara Alnasser)
The system must have protection against Denial-of-Service (DoS) attacks to ensure availability of the browser..

SR-13 (Author: Aljohara Alnasser)
The system must have strict access controls to prevent elevation of privilege in an unsecured browser environment.

SR-14 (Author: Aljohara Alnasser)
The system must create secure audit logs of critical security information to prevent repudiation and assist with the investigation of incidents.

SR-15 (Author: Aljohara Alnasser)
The system must validate every form of external input to aid in deterring or preventing tampering or injection-type attacks**.**

SR-16(Author: Rinas Naif)

The system must implement multi-factor authentication (MA) for all administrative access operations to prevent unauthorized control of sensitive security settings.

SR-17(Author: Rinas Naif)

The system should automatically terminate sessions for inactive users after a maximum of 5 minutes of inactivity to reduce the risk of session hijacking.

SR-18(Author: Rinas Naif)

The system must enforce secure domain name resolution via DNS over HTTPS (DoH) or DNS over TLS (DoT) to prevent domain name spoofing and data traffic interception.

SR-19(Author: Rinas Naif)

The system must isolate each web tag or process in the browser using protection techniques to prevent malicious code in one tab from affecting other sessions or system components.

SR-20(Author: Rinas Naif)

The system shall provide real-time monitoring and alerting for suspicious activities such as repeated failed login attempts or abnormal traffic patterns.

All requirements are SMART: specific, measurable, achievable, relevant, and testable.

Step 7: Categorize Requirements

Requirement ID	Category
SR-1	Confidentiality
SR-2	Confidentiality
SR-3	Integrity

SR-4	Integrity
SR-5	Availability
SR-6	Confidentiality
SR-7	Confidentiality
SR-8	Integrity/ Confidentialty
SR-9	Integrity
SR-10	Confidentiality
SR-11	Confidentiality / Integrity
SR-12	Availability
SR-13	Integrity
SR-14	Integrity
SR-15	Integrity / Availability
SR-16	Integrity / Confidentiality
SR-17	Confidentiality
SR-18	Confidentiality / Integrity
SR-19	Integrity
SR-20	Integrity / Availability

Step 8: Prioritize Requirements

Requirement ID	Priority
SR-1	High
SR-2	High
SR-3	High

SR-4	Medium
SR-5	Medium
SR-6	High
SR-7	High
SR-8	medium
SR-9	High
SR-10	Medium
SR-11	High
SR-12	High
SR-13	High
SR-14	Medium
SR-15	High
SR-16	High
SR-17	Medium
SR-18	High
SR-19	High
SR-20	Medium

Prioritization Criteria:
Requirements were prioritized based on their impact on user anonymity and the CIA triad.

Step 9: Inspect Requirements

All requirements were reviewed by the team to ensure correctness, clarity, consistency, and alignment with security goals. Revisions were made to eliminate ambiguity and confirm testability.

Exit Criteria: Approved and documented security requirements.

Team Contribution

The team used a peer-review approach to complete the project. Each section was assigned a team member to work on it and another team member to review it to ensure accuracy, completeness, and quality. This process helped maintain consistency across the document and meet all project requirements.

Team Member	**Project Section**	**Reviewed Portion**
Sarah Alakal	Product Assets+SR-1-SR-5	Malicious Actors & Threats+SR-16-SR-20
Meshael Alotabi	Product Assets+SR-6-SR-10	Malicious Actors & Threats+SR-11-SR-15
Aljohara alnasser	Malicious Actors & Threats+SR-11-SR-15	Product Assets+SR-6-SR-10
Rinas Naif	Malicious Actors & Threats+SR-16-SR-20	Product Assets+SR-1-SR-5

Table of content

1. Architecture Overview **3**

1.1 System Architecture Description 3

● Architecture diagram 3

1.2 Subsystems and Their Responsibilities 4

1.3 Security-Focused Subsystems 5

1.4 Impact of Developer Mistakes 6

1.5 Vulnerability-Prone Subsystems 6

1.6 Security in the Architecture 6

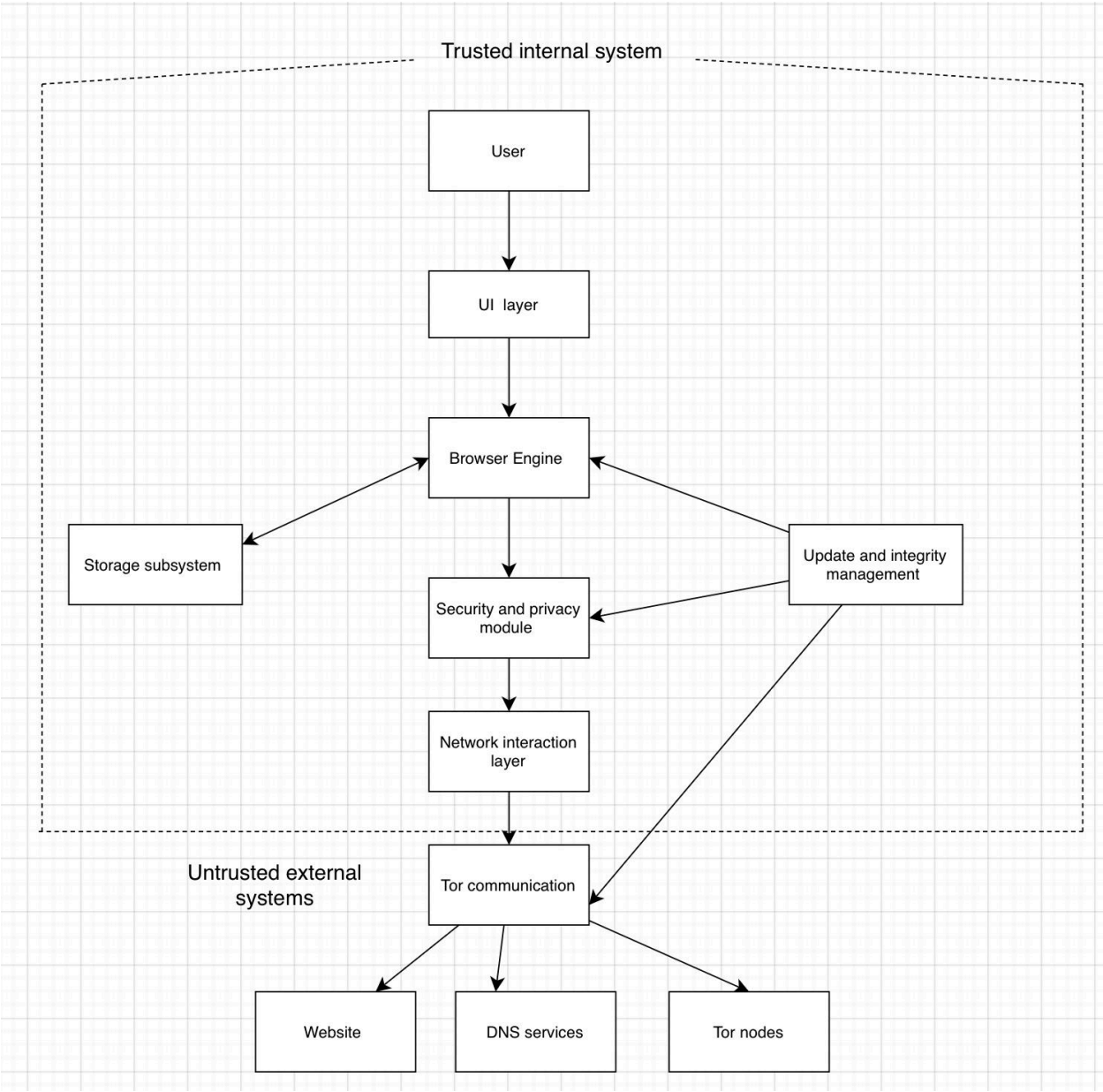
1.7 Impact of Subsystem Compromise 7
1.8 Risks from External Interactions 7
1.9 Future Changes in Architecture 7
2. Threat Model 8
2.1. Machine Boundaries 8
2.2. Trust Boundaries 8
2.3. Threats (use STRIDE) 9
2.4. Mitigations 9
2.5. Diagram 9
3. Assets to Threat Model Tracing 10
1. Map Assets to System 10
2. Does Location Affect Risk? yes 11
3. Missing Assets 11
4. Too Many Assets in One Place 11
4. Detailed Design 12
4.1 Onion Browser Class Diagram: 12
4.2 Onion Browser Sequence Diagram: 14
4.3 Secure Design Patterns and Principles: 15
5. Team Contribution 17

1. Architecture Overview

1.1 System Architecture Description

The architecture of The Onion Browser has been built using layers and modules; their main purposes are security, performance, and anonymity. In the system, every component has well defined functions, and there are strict controls governing how they interact with each other, thereby minimizing risks involved with these interactions. The separation of concerns is what limits the effects of possible attacks on the system and also helps to provide users with secure browsing over the Tor network.

- Architecture diagram



1.2 Subsystems and Their Responsibilities

1. Subsystem UI (User Interface)

- User is responsible for interacting with the browser

- User can enter a URL and configure settings in order for the system to appropriately display the web pages requested by the user.
- Warning messages can include phishing or insecure connections.
- The UI subsystem directly influences every user's decisions and helps to raise the user's security awareness.

2. Subsystem Browser Engine

- Renders the requested web pages while applying HTML and CSS; executes JavaScript.
- Provides a sandboxing-based approach to isolating different browser tabs from one another.
- As all of the code execution is handled through potentially untrusted content from the web, this subsystem is one of the most critical and vulnerable components of the entire system.

3. Subsystem Tor Communication

- All traffic is routed through the Tor network, creating connections that utilize multiple Tor nodes which are all encrypted.
- Preventing exposing the user's IP address is the main goal of this subsystem.

4. Module Security and Privacy Functions

- Enforcement of HTTPS connections, detection of potential phishing websites, scanning of downloaded files to determine the presence of known malware, and management of cookies and session data.
- The Security and Privacy Functions module provides the first line of defense against several types of possible attack vectors.

5. Subsystem Update and Integrity Management

Verifying whether updates have been digitally signed using crypto-graphic signature verification technology and ensuring that no malicious update has been installed serve to verify that only trustworthy code will be run by the browser.

6. Storage Subsystem

- The storage subsystem will store temporary files such as cookies and cache data.
- The storage subsystem will remove the storage file associated with each browsing session once a user has completed their browsing session to further protect the user's sensitive data from exposure.

7. Network Interaction Layer

- The network interaction layer connects:

  Tor network

  DNS services

  External websites

  It acts as the bridge between internal components and external systems.

1.3 Security-Focused Subsystems

Certain subsystems have been developed for the purpose of enforcing security. They include:

1. **Tor Communication subsystem:** This is a subsystem that allows someone to ensure anonymity by routing all their traffic through several destinations.
2. **Security and Privacy module:** The purpose of this module is to protect users against phishing (deceptive emails), malware and insecure connections.
3. **Update Management subsystem:** This subsystem has been designed to provide protection against supply chain attacks by verifying each update.

These subsystems are extremely important as they provide protection for user information and the user's identity.

1.4 Impact of Developer Mistakes

The consequences of developer mistakes will vary in accordance with their location.

- **Tor subsystem** → An error could result in IP address leakage and loss of anonymity
- **browser engine** → An error could allow an attacker to execute malicious code within a web browser.
- **security module** → An error could disable protections against phishing attacks.
- **update system** → An error could permit malicious code to be installed as part of the system update.
- **storage subsystem** → An error could expose sensitive information about users.

Even minor changes to carefully constructed systems can place an entire system at risk.

1.5 Vulnerability-Prone Subsystems

The subsystems listed below are more likely to have vulnerabilities in their coding.

Web Browser Engine

- Complex input and untrusted input.
- Has many bugs and vulnerabilities due to the complexity of code within web browser engine.

Security Module

- Logic errors that cause many of the protection mechanisms to disable.

Tor Communication Layer

- Sensitive to network attacks.

Because these subsystems are susceptible to vulnerabilities in the code, additional stringent tests and validations are required.

1.6 Security in the Architecture

Security is incorporated within the system according to several principles:

1. Defense in Depth: There are various levels of protection such as Tor routing, enforcing HTTPS, and employing sandboxing.

2. Least Privilege: Each component performs its function with as few access rights as possible.

3. Fail-Safe Design: In the case that Tor has failed, the browser will stop allowing traffic rather than exposing the user.

4. Distrustful Decomposition: Each subsystem assumes that all other systems may be untrustworthy

These principles provide a higher certainty that security will not be compromised due to one single point of failure.

1.7 Impact of Subsystem Compromise

Effects of system compromise are evident when one of the subsystems becomes compromised, which compromises the integrity of all other subsystems:

- If the Tor subsystem becomes compromised, the entire anonymity of the system will be rendered ineffective.

- If the browser engine becomes compromised, then an attacker may be able to execute malicious code on the computer.

- If the security module becomes compromised, it will be possible for an attacker to bypass the security protections offered by the security module.

1.8 Risks from External Interactions

- Interaction with Tor network via malicious exit nodes could allow for observation of traffic.
- Interacting with websites that contain tracking scripts/malware could compromise user confidentiality.
- Interacting with DNS services can introduce risks of interception and/or spoofing.

Encryption and extreme security protocols will provide mitigation of these risks.

1.9 Future Changes in Architecture

The architecture of the system will likely change over time as features/technologies are added like:

- Plugin support

- Implementation of anonymity improvements

- Integration of advanced security mechanisms

To ensure the security of the entire system as it expands, security assessments must be continuously performed to mitigate against emerging risks.

2. Threat Model

This section focuses on clarifying the potential risks that the Onion Browser system may face and how to address these threats using security mechanisms and designs tailored to the specific threat.

2.1 **Machine Boundaries:**

The system operates across several different environments, each with its own specific security levels and risks.

1. User Device: First, the system runs locally on the user's device. It includes:

* BrowserEngine

* SecurityManager

* StorageManager

Risks:

Attacks targeting the device

Infection of the device with malware

2. Tor Network:

Consists of several distributed nodes

Used as an anonymity layer

Risks:

One of the nodes may be compromised or malicious

3. External Servers

Kuwaiti websites represent:

Outside the system's control

Risks:

Phishing attacks

Malicious websites

2.2 Trust Boundaries

These represent the points through which the system transitions from a trusted environment to a risky one.

Key Trust Boundaries:

1. Browser and Internet:

Internet content is not trusted by default.

It is checked through the (security manager)

2. User's Device and Tor Network

Data exits the device to a semi-trusted external network.

3. Tor Exit Node and Website

At this point, data exits the Tor network to the internet.

If it is not encrypted, it can be intercepted.

Risks

Man-in-the-Middle (MITM) attack

Data espionage

Content modification

2.3 Threats (Using STRIDE Model)

1. Spoofing

Fake websites that resemble legitimate websites

Malicious nodes that pretend to be trusted

2. Tampering

Data modification during transmission

Injecting malicious code into web pages

3. Information disclosure

Real IP Address

Browsing Data

Sensitive Information

4. Denial of Service (DOS)

Stops or Slows Down the Service

Overloads the Network or Browser

5. Elevation of Privilege

Exploiting Changes to Gain Higher Privileges

Exiting the Sandbox

2.4 Mitigation Mechanisms

1. Identity Spoofing

Forcing HTTPS

Verifying Certificates

Blocking Suspicious Websites

2. Data Manipulation

Encrypting HTTPS Connections

Tor Multi-Layer Encryption

Verifying Inputs

3. Information Disclosure

Forcing All Traffic Through Tor

Preventing IP and DNS Leaks

Reducing the Storage of Sensitive Data

4. Denial of Service

Request Rate Limiting

Circuit Switching

Implementing Fail-Secure

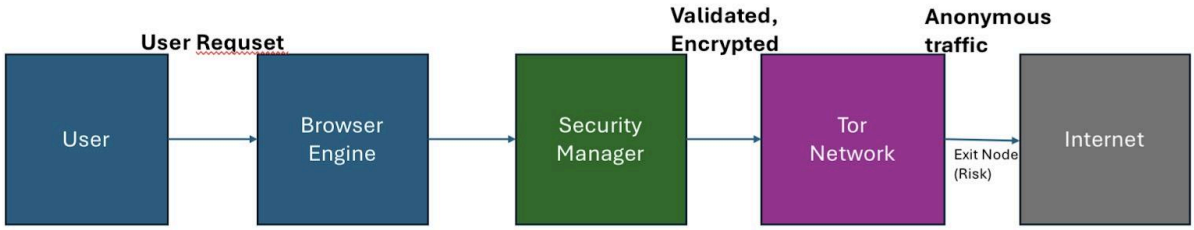
5. Elevation of Privileges

Using Sandbox to Isolate Tabs

Control Permissions

Implementing Zero Trust

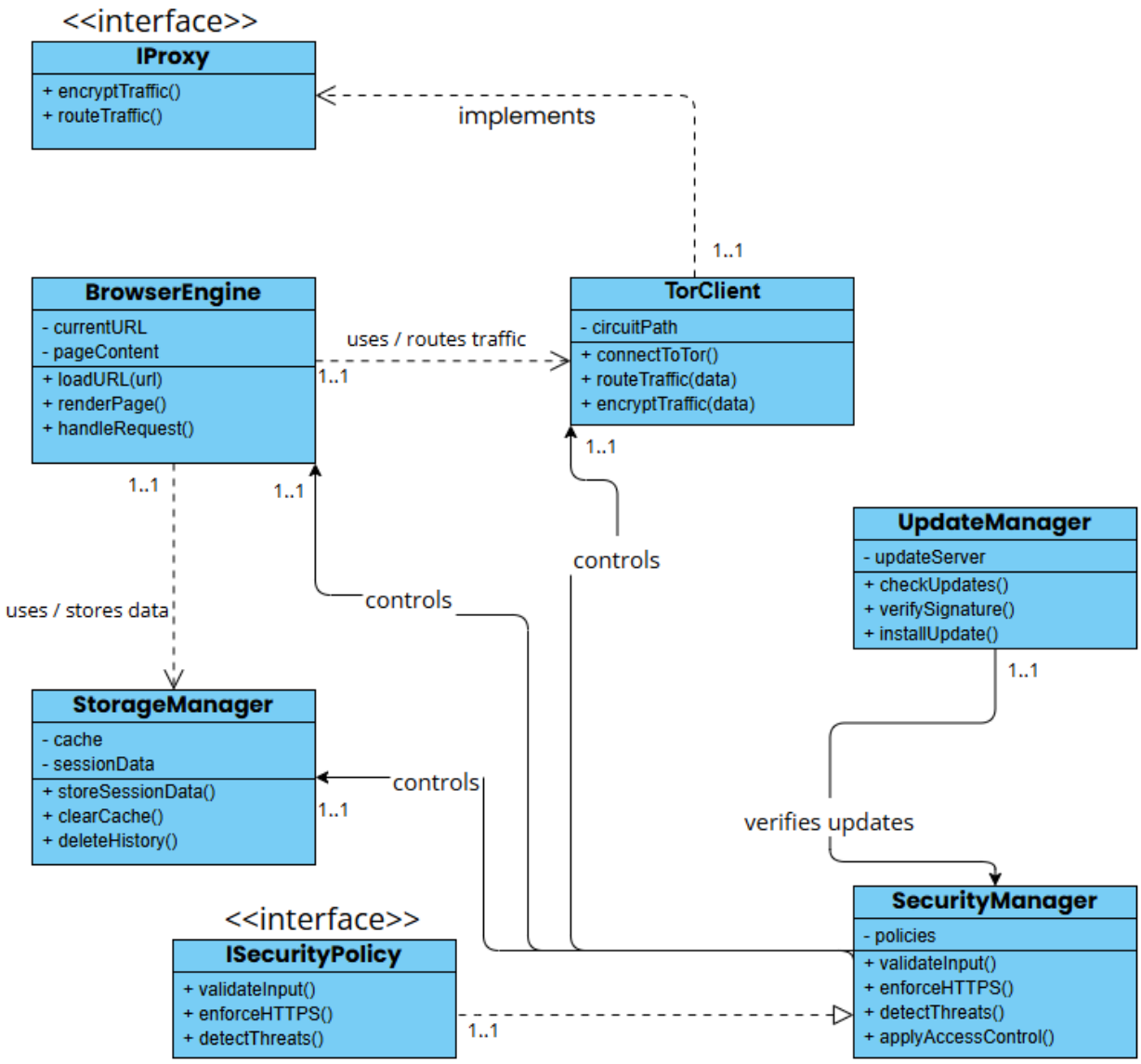
2.5 Threat Model Digram



This diagram illustrates how a user's request is securely routed within the Onion Browser system. The user begins by sending a request via the (browser engine), which is then checked and verified for security by the (security manager). Next, the request is routed through the (Tor network) to anonymize the user and encrypt all their data. Finally, the request reaches the (internet), and the response is returned along the same path to be displayed securely to the user.

4. Detailed Design

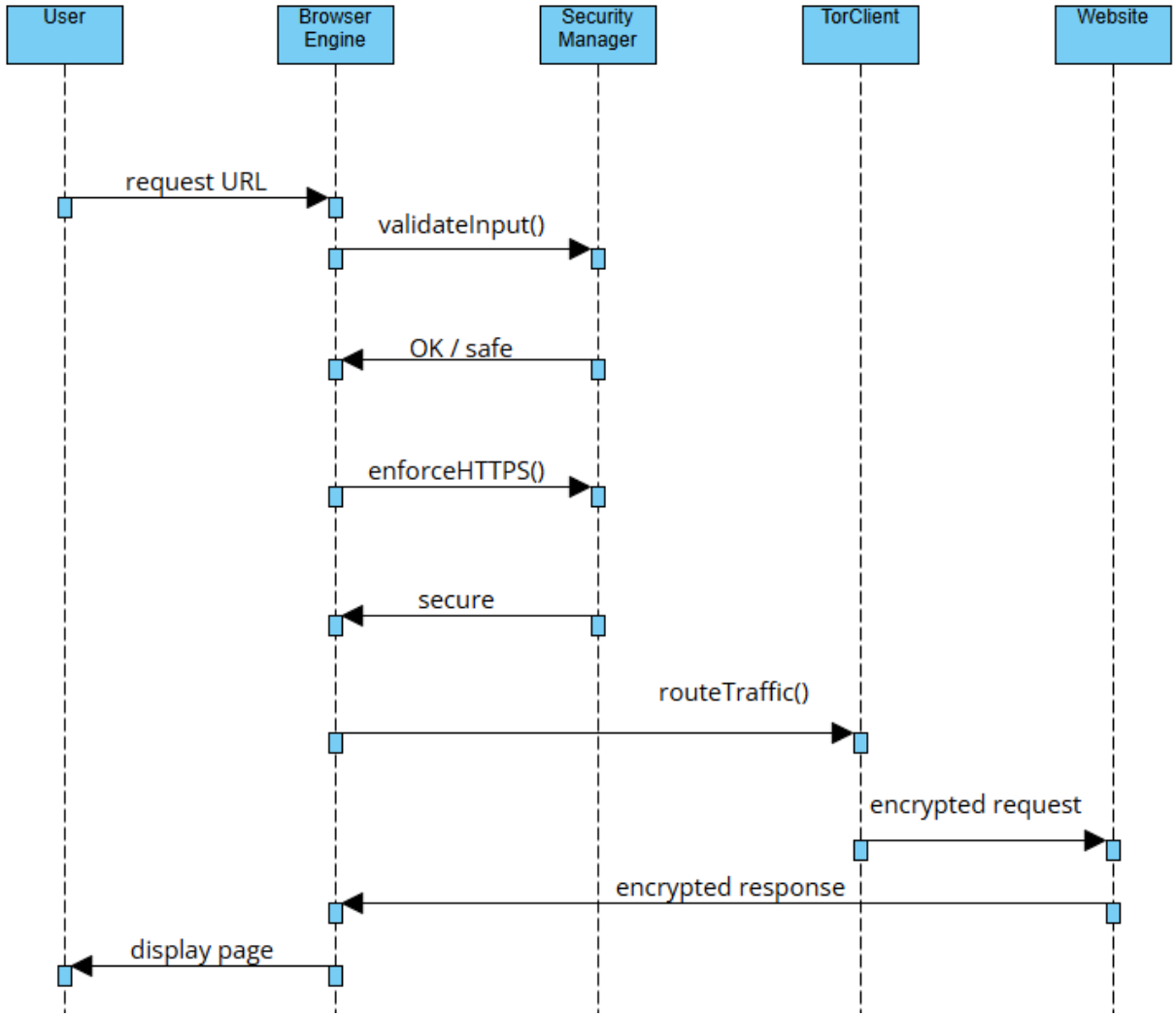
4.1 Onion Browser Class Diagram:



The class diagram represents the architecture of the Onion Browser system, where the BrowserEngine acts as the core component responsible for handling user requests and rendering web content. It interacts with the TorClient to route traffic anonymously through the Tor

network, following the Proxy design pattern, where the TorClient implements the IProxy interface to provide secure communication functions such as traffic routing and encryption. The StorageManager is used by the BrowserEngine to manage session data, cache, and browsing history. The SecurityManager is a central component that enforces system-wide security by validating inputs, enforcing HTTPS, detecting threats, and applying access control, and it implements the ISecurityPolicy interface to define standardized security rules. Additionally, the SecurityManager controls the BrowserEngine, TorClient, and StorageManager, ensuring consistent security enforcement across all components. The UpdateManager interacts with the SecurityManager to verify and securely install updates, maintaining system integrity. This design demonstrates modularity, separation of concerns, and the application of secure design principles such as proxy abstraction, centralized security control, and layered defense.

4.2 Onion Browser Sequence Diagram:



The sequence diagram illustrates how a user request is securely processed in the Onion Browser system. The user sends a request to the BrowserEngine, which forwards it to the SecurityManager for input validation and HTTPS enforcement, ensuring that all data is secure and trusted. After validation, the request is routed through the TorClient, which encrypts and transmits the data to the destination website. The website returns a response through the same secure path, and the BrowserEngine displays the page to the user. This process demonstrates secure communication, input validation, and anonymized traffic routing.

4.3 Secure Design Patterns and Principles:

To enhance the security of the Onion Browser system, several secure design patterns and principles have been implemented. These patterns help mitigate risks identified in the threat model and ensure robust protection of user privacy, data integrity, and system availability.

a. Sandbox Pattern

Description:
The system isolates browser tabs and processes in separate execution environments.

Role in System:
Each browsing session operates independently, preventing interaction between tabs.

Security Benefit:
If a malicious script or exploit affects one tab, it cannot spread to other tabs or compromise the entire browser.

Risk Reduced:

- Malware propagation
- Cross-site attacks
- Privilege escalation

b. Proxy Pattern (Tor Network Integration)

Description:
The TorClient acts as a proxy between the user and the internet.

Role in System:
All network requests are routed through multiple Tor nodes before reaching the destination.

Security Benefit:
The user's real IP address is hidden, and communication is anonymized.

Risk Reduced:

- User tracking
- IP address exposure
- Network surveillance

c. Defense in Depth

Description:
Multiple layers of security controls are implemented throughout the system.

Role in System:
SecurityManager, Tor encryption, HTTPS enforcement, and secure updates work together as layered defenses.

Security Benefit:
Even if one layer is compromised, additional layers continue to protect the system.

Risk Reduced:

- Data breaches
- Unauthorized access
- Exploitation of single vulnerabilities

d. Zero Trust Principle

Description:
The system assumes that all inputs and external interactions are untrusted by default.

Role in System:
All user inputs, web content, and network responses are validated by the SecurityManager.

Security Benefit:
Prevents malicious input from being executed or processed.

Risk Reduced:

- Injection attacks
- Malicious scripts
- Data tampering

e. Fail-Secure Principle

Description:
The system defaults to a secure state in case of failure.

Role in System:
If a secure connection cannot be established or validation fails, access is blocked.

Security Benefit:
Prevents accidental exposure of sensitive data during system errors.

Risk Reduced:

- Data leakage
- Insecure fallback connections
- Unauthorized access

5. Team Contribution

Team Member	**Project Section**	**Reviewed Portion**
Sarah Alakal	Detailed Design	Assets to Threat Model Tracing
Meshael Alotabi	Assets to Threat Model Tracing	Detailed Design
Aljohara alnasser	Architecture Overview	Threat Model
Rinas Naif	Threat Model	Architecture Overview